



T6 / T7

Incident Response Plan

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV9 (incident response plan + register), also evidences T6 (incident register) and T7 (data-breach / customer notification) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This plan defines how Lumi Reading detects, responds to, contains, eradicates, recovers from and learns from a security or privacy incident, and how it decides and executes notification to affected schools/individuals and the OAIC. It uplifts the existing data-breach response plan and tabletop record ([docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#)) into a full incident response procedure with an incident register. Where a control or appointment is pending, it is called out (see §11).

Scope: a suspected or confirmed compromise of the confidentiality, integrity or availability of Lumi personal information or systems — the Flutter app, Cloud Functions, [packages/server-ops](#), the two Next.js portals, the marketing site, the security rules, and the data held in [lumi-ninc-au](#) ([australia-southeast1](#)). This document is a procedure, not legal advice; the incident lead must obtain Australian privacy/legal advice when a breach may cause serious harm or a notification decision is uncertain.

The structure follows the OAIC's data-breach preparation-and-response guidance, as does the source plan.

2. Roles and authority

Named appointments are recorded authoritatively in [docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#) §1 (roles table). While Lumi is small, one person may hold several roles, but **every action must be recorded** (§10 register).

Role	Responsibility	Holder
Incident lead	Declare severity, coordinate, preserve timeline, approve containment	Nic (Director); authorised backup named in the breach-response plan
Technical lead	Containment, evidence, eradication, recovery, verification	Nic (Director); backup coordinates approved technical assistance
School liaison	Verify school authority; coordinate affected-school communication	Nic (Director) / backup
Communications	Clear, child-safe notices; no speculation	Nic (Director) / backup
Scribe	Time-stamped decisions, evidence chain, action list	Nic (Director) until delegated
Privacy / legal lead	NDB assessment, regulator liaison, school/individual notice	Unappointed — external Australian privacy counsel required

The incident lead is authorised to disable a feature, revoke credentials or sessions, block a deployment, enforce maintenance mode, suspend a school, or temporarily stop processing to protect people. **Destructive evidence deletion is not authorised.**

Formal appointment (GO1/GO2). The named security-officer (GO1) and privacy-officer (GO2) appointment letters that formally back these roles are drafted but **pending signature** ([docs/security/ASSESSMENT_STATUS.md](#) records GO1/GO2 as *Not Ready*). The operational role assignments above are already confirmed in the breach-response plan; the signed officer letters are the outstanding governance artefact (§11).

3. Detection and reporting

An incident can be raised from any of these channels:

- **Automated operational alerts.** Cron-heartbeat and storage-usage metrics are written to the `opsMetrics` collection (deny-all to clients); threshold alert policies are attached to **two separate security-alert inboxes** (a primary operational address and an independent backup), and the admin dashboard polls the metrics. Delivery to both inboxes was verified in the tabletop (a synthetic Cloud Monitoring incident reached both). See the monitoring plan §8 and `docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`.
- **Function-health audit.** `scripts/audit-function-health.sh` catches silent backend failures (invoker-403s, dropped events, failed crons, stale heartbeats); it auto-runs after a functions deploy or IAM change.
- **Security-scan findings.** Escalated from the CI scanners / findings register (EV13 §5, monitoring plan §5) when a live-exploitable issue is found.
- **External reports.** A researcher or member of the public reports via the privacy/support intake mailbox recorded in the breach-response plan (`support@lumi-reading.com`, owner-confirmed monitored daily + MFA-protected).
- **Firestore Data Access audit logging** (`DATA_READ` / `DATA_WRITE`) is enabled project-wide, so a suspicious access pattern leaves evidence even below the cost threshold that ordinary metrics would surface.

On report: the receiver records UTC + local time, reporter, observable symptoms and an incident ID, and notifies the incident lead. For a SEV-1 the backup lead is notified within 15 minutes (§4).

4. Triage and severity

Severity drives response speed and is re-assessed as scope becomes clear

(`docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md` §2).

Severity	Example	Initial response target
SEV-1 Critical	Confirmed cross-school/child exposure, stolen privileged credential, public Storage, destructive compromise	Begin immediately; notify backup lead within 15 min
SEV-2 High	Likely unauthorised access with limited scope, deletion failure leaving data accessible, suspicious impersonation	Begin within 30 min
SEV-3 Medium	Blocked attack, contained non-production leak, incorrect adult-only email	Same business day
SEV-4 Low	No personal-data or control impact	Track in normal security work

5. Containment

Protect people first: stop the affected feature or tenant if the exposure is ongoing. Revoke exposed keys, sessions, tokens and signed URLs **without** destroying evidence. Preserve the relevant Cloud Audit, Cloud Run, Firebase, GitHub/deployment and application audit records with restricted access. The event-specific safe actions are the technical containment map (`docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md` §5), summarised:

Event	Immediate safe actions
Firestore Rules regression	Roll back to last reviewed ruleset; suspend affected client version; compare active rules hash; add negative test
Storage exposure / signed-URL leak	Restore Storage Rules/IAM; revoke signer capability; replace exposed object generations; inspect egress
Service-account / API-key leak	Disable first, verify healthy ADC/WIF path, delete key, restrict API key, inspect Cloud Audit Logs
Compromised user / session	Disable Auth user, revoke refresh tokens, remove sessions/impersonation, verify memberships
Audio/AI vendor incident	Set feature kill switch off, stop the queue/worker, preserve minimum job metadata, request provider containment/deletion evidence
Deletion-workflow failure	Keep the job resumable, stop unsafe destructive retries, inventory expected records, repair and rerun idempotently
Malicious / risky release	Activate force-update/support mode, halt rollout, revert backend compatibility if needed

Feature-level containment without a deploy is available: kill switches and entitlement flags are Firestore-doc-driven (EV13 §8), so an affected feature can be turned off by flipping a document.

6. Eradication

- Establish and fix the **root cause**; add a regression test that fails on the vulnerability before it is closed (rules fixes → `functions/test/security_poc.rules.test.js`).
- Rotate any credential, key or session that was, or may have been, exposed; confirm the healthy keyless (WIF/ADC) path before deleting a leaked key.
- Confirm no residual foothold (impersonation grants, orphaned sessions, altered membership/role documents, injected data).

7. Recovery

- Restore service only after verifying deployed **rules/config/code hashes**, runtime IAM, App Check state, API-key restrictions, Storage access and affected data integrity against the reviewed known-good baseline.
- Re-run the cross-tenant negative tests (Firestore Emulator matrix) and a production synthetic-denial probe against the restored state.
- Confirm alerts again reach both security inboxes.
- Back-out data recovery uses backups / PITR (7-day PITR + deletion protection; a restore drill matched production counts — `docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md`). Note: a Firestore document deletion does **not** instantly purge PITR versions; record when inaccessible backup/PITR data ages out.

8. Notification — customers and OAIC (T7)

Notification is a **legal assessment, not a record-count threshold**, and is led by the privacy/legal lead (currently unappointed → external Australian counsel must be engaged, §11).

- **Schools.** Notify affected schools through a **separately verified emergency contact** (contract/CRM), never a possibly-compromised in-app account. A holding notice template is in the source plan §7.
- **Individuals + OAIC (NDB scheme).** If there are reasonable grounds to believe an **eligible data breach** has occurred — unauthorised access/disclosure or likely loss, **likely serious harm**, and inability to prevent that harm by remedial action — prepare the OAIC statement and notify affected individuals in the legally appropriate way. A **suspected** eligible breach triggers a prompt assessment (the OAIC's 30-day expeditious-assessment expectation); the assessment must not be allowed to silently drift beyond the statutory period.
- **Content of notices.** What happened, what information was involved, the practical risks, containment already taken, what people should do, and how to get support — in plain, child-safe language, with no speculation.
- **Coordination.** Time notification with law enforcement / cyber-insurer / providers only where relevant; document any delay and its authority.

Harm assessment must weigh child-specific risks: identity fraud, physical safety, humiliation, discrimination, educational harm, family conflict, and risk created by a child's voice or location.

9. Communications and workarounds

- **In-app status banner.** When users must be told something out-of-band (e.g. a Firebase outage or an enforced maintenance window), the operator publishes a banner via the Cloudflare status worker — runbook `docs/status-messages.md`, helper `scripts/status-message.sh` — with `info` / `warn` / `critical` severity (critical is non-dismissible).
- **Force-update / support mode** halts a malicious or unsafe app version and points users at a safe build.
- All external wording is child-safe and speculation-free; the holding-notice template is the starting point.

10. Incident register (T6)

Every incident is recorded in a standing incident register held **outside** the production systems and the ordinary support inbox, in a dedicated access-restricted location (§ evidence handling, source plan §4). The register carries every T6 field:

#	Incident ID	Date occurred	Date discovered	Severity	Description	Actions taken (containment → recovery)	Person / authority reported to	Notification decision (schools / individuals / OAIC)	Status	Post-incident review date
1	INC-2026-...	(UTC + local)	(UTC + local)	SEV-...	...	...	...	...	Open/Closed	...

Field notes: **Date occurred** and **date discovered** are recorded separately (they are frequently different); **actions taken** is the running timeline the scribe maintains; **person/authority reported to** captures internal escalation *and* any external report (school emergency contact, OAIC, law enforcement, insurer). Evidence is hashed on export, with collector/source/UTC-time/transfer recorded; tokens, keys, raw cookies and child recordings are never printed to a transcript (source plan §4).

As of this draft the register holds no real incidents — only the tabletop walkthrough (§12). It must be stood up as a live document at the location the breach-response plan designates (§14).

11. Post-incident review

A **blameless review** is held within five business days of containment: root cause, what worked, what didn't, lessons, owners and deadlines; update the PIA, vendor register, threat model and school FAQ as needed. Fixed root causes carry a regression test before service is restored (§6).

12. Tabletop exercise on record

A desk-based technical walkthrough was run **17 July 2026** ([docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md](#) §6): a broad Firestore Rules change lets a School-A teacher query School-B reading logs for two hours; ~500 child records (names, book titles, minutes, optional comments) reportedly seen. The walkthrough exercised SEV-1 declaration, rules rollback, evidence preservation, cross-tenant negative testing, scoped data inventory, verified school contact, NDB assessment start, holding notice, and a five-day review.

Result: the process is technically executable. Closed during the exercise: alert delivery to both inboxes, operational role assignment (incident/technical leads), Firestore Data Access audit logging. Left open: verified per-school emergency contacts (not in the repo), an appointed external privacy/legal lead, and store-attested App Check. The exercise explicitly did **not** prove that an NDB notification decision has been legally reviewed.

13. Supporting evidence index

Control	Evidence
Source breach-response plan + tabletop record	docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md
Operational alerts / dual inboxes / backups	docs/security/OPERATIONS_HEALTH_AUDIT_2026-07-17.md , monitoring plan §8
Function-health audit	scripts/audit-function-health.sh
Rules-regression rollback + regression test	functions/test/security_poc.rules.test.js , EV13 §8
Feature kill switches (containment without deploy)	EV13 §8
Status-banner comms runbook	docs/status-messages.md , scripts/status-message.sh
Release-hash verification (recovery)	docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md
Officer-appointment status (GO1/GO2)	docs/security/ASSESSMENT_STATUS.md

14. Known gaps (for the reviewer)

- **GO1/GO2 letters need signing.** The named security-officer and privacy-officer appointment letters are drafted but **pending signature**; until signed, the formal governance behind the roles in §2 is incomplete.
- **Privacy/legal lead unappointed.** The NDB-assessment / OAIC-liaison role has no appointed holder — external Australian privacy counsel must be engaged, and the notification timelines in §8 confirmed against OAIC obligations with that adviser. Do not read this plan as asserting an NDB decision capability in-house.

- **Incident register stood up.** §10 provides the template; confirm the live register exists at the designated access-restricted location, is reviewed on a set cadence, and that a named owner keeps it.
- **School emergency-contact register.** Verified per-school emergency contacts are **not** in the repository (a tabletop gap). Notification (§8) depends on this existing in the contract/CRM.
- **App Check (F-05).** Store-attested client attestation is **not yet enforced** (launch-gated); it would reduce scripted exploitation but does not correct broken authorisation. Noted so the plan is not read as claiming it.
- **Sign-off.** This plan requires Nic's sign-off (and privacy-adviser review of §8) before it is the governing document.